

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(15)

Apothem AB
Decision following supervision under the
Data Protection Regulation – Apothem
AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (IMY) finds that Apothem AB (559094–8401) has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing to implement appropriate technical and organizational measures to ensure a suitable level of security for personal data when using the analytics tool Meta-pixel during the period from April 15, 2021, to April 26, 2022.

The Swedish Authority for Privacy Protection decides, based on Articles 58.2 and 83 of the Data Protection Regulation, that Apothem AB shall pay an administrative fine of 8,000,000 Swedish kronor.

Report on the supervisory case

Background, etc.

The Swedish Authority for Privacy Protection (IMY) received a notification of a personal data incident from Apothem AB (Apothem or the company) on May 14, 2022. The notification indicated that Apothem had transferred more personal data than intended to Meta Platforms Limited Ireland (Meta) for customers who had consented to marketing cookies in the company's cookie consent manager. The transfer had occurred through a Meta-pixel that was implemented on the company's website. The data that had been transferred to Meta included contact details and purchase information but no information regarding prescription medications. The company became aware of the transfer through an external source and subsequently chose to disable the pixel.

IMY initiated supervision of Apothem on May 31, 2022, based on the information contained in the notification. The supervision has been limited to the question of whether Apothem has taken appropriate technical and organizational measures in accordance with Article 32 of the Data Protection Regulation.

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Case number:
IMY-2022-3272

Date:
2024-08-29

Swedish Authority for Privacy Protection
Case number: IMY-2022-3272
2(15)
Date: 2024-08-29

The processing at IMY has been conducted through written correspondence with Apothem. IMY has also obtained information from Meta regarding how the Meta-pixel and its filtering mechanism work. What Apothem has stated
Apothem has primarily stated the following in the supervisory case regarding the issue under review.

Data Controller

It is Apohem's view that the company is jointly responsible for data processing with Meta for the implementation of the pixel and the subsequent transfer of personal data to Meta. Apohem is a data controller by having implemented the pixel on its website and subsequently transferred personal data to Meta. Meta has a data controller responsibility as they have developed and provide the code for the pixel.

Purpose of the processing

The Meta-pixel has been implemented and used on the website www.apohem.se to market products on Meta's platforms (Facebook and Instagram). With the help of the pixel, Apohem has collected information about purchases and behaviors on the website to then share the information with Meta, intending to attribute behaviors and completed purchases on the website to the marketing conducted via Meta. The purpose has been to design and target personalized advertisements to website visitors, thereby making offers more relevant to them than would be the case with general advertising. The advertisements would pertain to more general marketing of Apohem and its products or a campaign regarding a specific product/brand.

Apohem did not intend to use the pixel's sub-function Automatic Advanced Matching (AAM), which was the cause of the unintentional transfer of personal data to Meta. The company's internal investigation could not show that an individual had activated the function or the date of activation. However, it is assessed as most likely that the function was activated in connection with a change of the company's e-commerce platform on April 15, 2021, which means that the unintentional transfer of data occurred during the period from April 15, 2021, to April 26, 2022.

Which personal data was transferred to Meta

For website visitors who consented to marketing cookies on Apohem's website and who did not have ad-blocking browser extensions installed, the following personal data was transferred to Meta through the pixel:

-

IP addresses

-

purchase information (category, product group, and names of goods and other non-prescription products, product code, quantity, and price), and

-

website behavior/activated events (visited page, visited product page, added to cart, proceeded to checkout, completed purchase).

Through the AAM function, Apohem also unintentionally transferred data to Meta regarding website visitors who consented to marketing cookies, added products to the cart, and proceeded to fill out the form at checkout in the form of:

-

first and last name

-

email address

Swedish Data Protection Authority

Diary Number: IMY-2022-3272

3(15)

Date: 2024-08-29

-

telephone number and

-

address details (city, postal code, country).

No information regarding prescription medications has been transferred, only information about commercial goods (products for body and well-being, cosmetics, hygiene products, and various types of household products) and non-prescription products in the company's range. The pixel code has been installed on those parts of the website where the following products and/or product categories

have been present:

- a) Self-tests and treatment for sexually transmitted diseases
- b) Contraceptives and morning-after pills
- c) Sex toys
- d) Products for vaginal health, e.g., dry mucous membranes, menopausal symptoms, and yeast infections
- e) Products for prostate issues and urinary problems
- f) Pregnancy tests, ovulation tests, and pregnancy products
- g) Products for the treatment of fungal infections, e.g., athlete's foot and nail fungus
- h) Products for the treatment and management of diabetes
- i) Products for the treatment of rectal issues, e.g., anal fissures and hemorrhoids
- j) Products for the treatment of stomach issues, e.g., IBS, constipation, and diarrhea
- k) Products for the treatment of migraines
- l) Products for the treatment of allergies
- m) Accessories for hearing aids
- n) Products for the treatment of bacterial infections
- o) Products for the treatment of psoriasis
- p) Products for the treatment of rosacea
- q) Stoma products.

Information about these products/product categories has not been processed by Meta's advertising system despite the pixel code. Meta has a policy regarding the type of information that users of the pixel are allowed to transfer to them. Therefore, there is a filtering mechanism associated with the pixel that is intended to detect and delete information about, among other things, diseases, health conditions, sexual and reproductive health, medical procedures/treatments/tests, supplements/medications (both over-the-counter and prescription), biological cycles, etc. Apohem has not received any information from Meta indicating that such data has been transferred to Meta. If Apohem had received such information, the cause would have been investigated and measures taken. In the event that such information has been transferred to Meta, of which Apohem has not been notified, there has been no risk that the data has been processed by Meta's advertising system, but only for the purpose of deletion.

Apohem does not consider the products/product categories listed above to constitute health data or other sensitive information. The person purchasing commercial goods and other non-prescription products from the company is not necessarily the same person who ultimately uses the product. Purchases of non-prescription products do not necessarily provide direct information about a person's health status, as the same product can be used for various purposes and serve different functions for different individuals. Many of the products can also be purchased and used without the individuals who subsequently use the product having any health issues.

Apohem has further made selections and categorizations of products that would be processed by the pixel and thus marketed in Meta's channels. This was done based on the exclusion of the following products/categories:

Integrity Protection Authority

Diary Number: IMY-2022-3272

4(15)

Date: 2024-08-29

- products regulated by specific marketing provisions and regulations, e.g., OTC, dietary supplements, and medical devices,
- products that cannot be marketed to consumers according to law, e.g., infant formula and prescription medications, and
- products that cannot be marketed on Meta's platforms, e.g., sex toys.

To ensure that the products Apohem made available to Meta adhered to this selection, Apohem implemented a filter in its product feed. This product feed is updated daily based on the available products in the company's assortment and is then retrieved daily by Meta. Therefore, it is only these

products that have been marketed to website visitors who have an account on Facebook or Instagram. The total share of the company's sales that consisted of products listed under items a–q amounted to 5.7 percent during the period from April 15, 2021, to April 26, 2022.

Scope of the Incident

Apothem assesses that personal data related to approximately 15,000 registered individuals has been transferred to Meta during the relevant period. This is based on the number of unique customers who (1) accepted cookies according to the company's cookie consent manager, (2) did not have ad-blocking browser extensions installed, (3) did not have an active cookie from Facebook or Instagram in their browser, but (4) held an account on Facebook or Instagram and could thus be matched through the AAM function. According to information from Meta, the proportion of customers that could be matched through AAM was approximately 3 percent.

The company does not believe that the unintentional transfer of personal data to Meta has negatively affected the registered individuals. This is because neither sensitive personal data, personal identification numbers, nor financial information was included in the transfer.

Technical and Organizational Security

Apothem regularly takes measures to ensure the correct processing of personal data before, during, and after the implementation of new features on the website. The company has governing documents and established procedures in place to ensure internal data protection work. These include, among other things, that a mapping must be conducted before a new functionality is implemented that requires documentation, a correct legal basis, retention procedures, and information to the registered individuals. There are retention periods for the systems used by the company and a designated product owner for each system responsible for ensuring that personal data in the system is handled correctly. In addition, there are governing documents regarding personal data incidents and the handling of the rights of the registered individuals.

Apothem follows jointly developed industry guidelines in the area from Swedish Trade. These include Guidance on Personal Data, Cookies, and Other Tracking Technologies, as well as the General Data Protection Regulation and Personal Data – an Interpretation Guide in the Practical Data Protection Work for Member Companies of Swedish Trade. The company also follows the instructions of the E-health Authority, including in accordance with the supplementary pharmacy data law (2009:367).

When implementing the Meta pixel, Apothem assessed that there was not a high risk to the registered individuals' freedoms and rights and that the processing of personal data was proportionate in relation to the measures taken by the company. The organizational protective measures taken to safeguard the data processed via the pixel included access control. This meant that only one person at the company had full administrative access to a specific account with Meta to manage the pixel.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3272

5(15)

Date: 2024-08-29

The appointed person, in turn, determined which individual persons with personal logins in the marketing and IT department at Apothem, as well as contracted partners for marketing, had a need for access to manage it. Since it was not relevant to change the information that would be collected through the Meta pixel, Apothem did not conduct regular follow-ups on which personal data was collected and processed. Instead, Apothem relied on Meta's filtering mechanism, which means that no information beyond what is approved according to Meta's policy should be collected via the pixel. The company did not intend to use the AAM function and therefore did not actively take any measures specifically related to the function. Nor was there any risk assessment regarding the function. The personal data processed in AAM was, however, hashed using the SHA-256 hashing algorithm before being transferred to Meta. When Apothem discovered the unintentional transfer of personal data, the company immediately disabled the pixel, including the AAM function, and reported a personal data incident to IMY. In connection with this, Apothem also contacted Meta with questions about the

incident, but Meta has not responded to Apohem's inquiries. After the report of the personal data incident was made, the company implemented several organizational protective measures to detect unauthorized outgoing traffic. These included developing new internal governing documents and procedures, as well as increasing legal support from the DSO, Head of Legal and Compliance, and contracted law firms.

Justification of the Decision

IMY must initially determine whether the General Data Protection Regulation (GDPR) is applicable and whether IMY is the competent supervisory authority. If so, IMY should assess whether Apohem is the data controller and whether the company has taken appropriate security measures according to Article 32 of the GDPR to protect the personal data processed through the Meta pixel, with the AAM function activated, during the period from April 15, 2021, to April 26, 2022.

IMY's Competence

Applicable Provisions

According to Article 95 of the GDPR, the GDPR shall not impose any additional obligations on natural or legal persons processing personal data for areas already covered by obligations under the so-called ePrivacy Directive. The ePrivacy Directive has been implemented in Swedish law through the Act (2003:389) on Electronic Communication (LEK), which regulates, among other things, the collection of data through cookies.

According to Chapter 9, Section 28 of LEK, which implements Article 5.3 of the ePrivacy Directive, data may only be stored in or retrieved from a subscriber's or user's terminal equipment if the subscriber or user is provided with information about the purpose of the processing and consents to it. Furthermore, it is stated that this does not prevent such storage or access that is necessary for the transmission of an electronic message via an electronic communications network or that is necessary for providing a service.

2 IMY's addition: Hashing is a cryptographic one-way function that can be used to achieve pseudonymization, which is a possible security measure according to Article 32 of the GDPR, by replacing personal data with a so-called hash value. This means that the replaced personal data is not available in clear text and that additional information is needed to identify the data subject.

3 Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, on the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications).

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3272

6(15)

Date: 2024-08-29

as expressly requested by the user or subscriber. The Electronic Communications Act (LEK) came into force on August 22, 2022. However, during the relevant period of this case, the same requirements applied according to Chapter 6, Section 18 of the Act (2003:389) on Electronic Communications. The Swedish Post and Telecom Authority (PTS) is the supervisory authority according to LEK (Chapter 1, Section 5 of the Regulation [2022:511] on Electronic Communications).

The European Data Protection Board (EDPB) has commented on the interaction between the ePrivacy Directive and the General Data Protection Regulation (GDPR). The opinion states, among other things, that the national supervisory authority designated under the ePrivacy Directive is solely competent to monitor compliance with the directive. However, the supervisory authority under the GDPR is the competent supervisory authority for processing that is not specifically regulated by the ePrivacy Directive. If only part of the processing falls under the ePrivacy Directive, this does not limit the data protection authority's power to assess other parts of the processing under the GDPR.

IMY's Assessment

IMY's review focuses on a situation where customers have used a service on Apohem's website to order a product and have themselves provided the information captured by the Meta pixel. This

information management does not involve data being stored in or retrieved from a subscriber's or user's terminal equipment and is therefore not covered by Chapter 9, Section 28 of the LEK or the previously applicable corresponding provision in the Act (2003:389) on Electronic Communications. IMY thus concludes that the GDPR is applicable to the relevant personal data processing and that IMY is the competent supervisory authority. It can further be noted that IMY's review concerns whether the company has taken sufficient security measures, which is not specifically regulated in the LEK. This circumstance also means that IMY is the competent supervisory authority.

Data Controller

Applicable Provisions

The data controller is, according to Article 4.7 of the GDPR, the entity that alone or jointly with others determines the purposes and means of processing personal data. The fact that purposes and means can be determined by more than one actor means that multiple actors can be data controllers for the same processing.

The data controller shall, according to Article 5.2 of the GDPR, be responsible for and be able to demonstrate compliance with the principles in Article 5.1 (the principle of accountability).

The Court of Justice of the European Union has stated in the case Fashion-ID that a website operator using so-called plugins from social networks on their website may be jointly responsible with the social network for data processing. This applies to the collection and disclosure of website visitors' personal data that occurs through the social network's plugins. The court also stated that each party is only responsible for the parts of the processing chain for which it has actually determined the purposes and means.

4 Opinion 5/2019 on the interaction between the ePrivacy Directive and the General Data Protection Regulation, particularly regarding the competence, tasks, and powers of data protection authorities, adopted on March 12, 2019, paragraphs 68–69.

5 Judgment of the Court of Justice of the European Union on July 29, 2019, Fashion ID, C-40/17, EU:C:2019:629, paragraphs 64–85.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3272

7(15)

Date: 2024-08-29

IMY's Assessment

Apothem has stated that there is a joint data controller responsibility together with Meta for the implementation of the pixel on the company's website and the subsequent transfer of personal data to Meta.

In the context of this case, IMY only assesses whether Apothem has a data controller responsibility for the collection and transfer of personal data that occurred through the use of the Meta pixel with the AAM function activated. IMY thus does not take a position on whether there is a joint data controller responsibility together with Meta for the relevant processing.

The investigation in the case shows that Apothem has decided to implement the Meta pixel, a script-based tool in the form of a code snippet that records visitors' actions and transfers the information to Meta, on its website. The purpose has been to increase the efficiency of the company's marketing and to target advertisements to previous visitors to the website. Apothem has thus determined for what purpose the personal data will be processed and how the processing will take place. Against this background, IMY assesses that Apothem is the data controller for the processing of personal data that occurred through the use of the Meta pixel with the AAM function activated.

Has Apothem ensured an appropriate level of security for the personal data?

Applicable Provisions

The requirement to take appropriate protective measures

According to Article 32.1 of the General Data Protection Regulation, the data controller shall implement appropriate technical and organizational measures to ensure a level of security that is appropriate in relation to the risk of the processing. This shall, according to the same provision, be done taking into

account the latest developments, the implementation costs, and the nature, scope, context, and purposes of the processing as well as the risks, varying in likelihood and severity, to the rights and freedoms of natural persons. According to Article 32.1, appropriate protective measures, where appropriate, include:

- a) pseudonymization and encryption of personal data,
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and
- d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

In assessing the appropriate level of security, special consideration shall be given, according to Article 32.2, to the risks posed by the processing, in particular from accidental or unlawful destruction, loss, or alteration, or to unauthorized disclosure of or access to the personal data that has been transferred, stored, or otherwise processed.

Recital 75 of the General Data Protection Regulation states factors that should be considered in assessing the risk to the rights and freedoms of natural persons. Among other things, it mentions the loss of confidentiality concerning personal data that is subject to confidentiality obligations as well as whether the processing concerns data about health or sexual life. Furthermore, consideration should be given to whether...

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3272

8(15)

Date: 2024-08-29

The processing concerns personal data about vulnerable individuals, primarily children, or if the processing involves a large number of personal data and concerns a large number of registered individuals.

In Recital 76 of the General Data Protection Regulation (GDPR), it is stated that the likelihood and severity of the risk to the rights and freedoms of the data subject should be determined based on the nature, scope, context, and purposes of the processing. The risk should be assessed based on an objective evaluation, through which it is determined whether the data processing involves a risk or a high risk.

Processing of Sensitive Personal Data

Data concerning health and sexual life constitutes special categories of personal data, so-called sensitive personal data, which are afforded particularly strong protection under the GDPR. As a general rule, it is prohibited to process such personal data according to Article 9.1 of the GDPR, unless the processing falls under one of the exceptions in Article 9.2 of the Regulation.

Data concerning health is defined in Article 4.15 of the GDPR as personal data relating to the physical or mental health of a natural person, which provides information about their health status.

In Recital 35 of the GDPR, it is stated that personal data concerning health should include all data relating to a registered person's health condition that provides information about the registered person's past, present, or future physical or mental health condition.

The Court of Justice of the European Union (CJEU) in the case of Lindqvist established that information about a person having injured their foot and being partially sick-listed constitutes personal data concerning health according to the Data Protection Directive (the directive was repealed by the GDPR). The CJEU stated in the case that, considering the purpose of the Data Protection Directive, the term "data concerning health" should be given a broad interpretation and is considered to encompass data relating to all aspects of a person's health, both physical and mental. The CJEU further noted in a later ruling, Vyriausioji tarnybinės etikos komisija, that the concept of sensitive personal data under Article 9.1 of the GDPR should be interpreted broadly and assessed that even personal data that indirectly, through intellectual inference or assessment, reveals a natural person's

sexual orientation constitutes sensitive personal data under the relevant provision.

IMY's Assessment

The processing has involved a high risk and required a high level of protection.

The data controller must take measures to ensure a level of protection that is appropriate based on the risks associated with the processing. The assessment of an appropriate level of protection should be made taking into account, among other things, the nature, scope, context, and purposes of the processing as well as the risks, of varying degrees of likelihood and severity, to the rights and freedoms of natural persons. Special consideration should be given to the

6 Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data.

7 Judgment of the CJEU of 6 November 2003, *Lindqvist*, C-101/01, EU:C:2003:596, paragraphs 50–51.

8 Judgment of the CJEU of 1 August 2022, *Vyriausioji tarnybinės etikos komisija*, C-184/20, EU:C:2022:601, paragraphs 123–127.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3272

9(15)

Date: 2024-08-29

risks associated with the processing, including unauthorized disclosure of or unauthorized access to personal data.

The investigation in the matter shows that the use of the Meta pixel and the activation of the AAM function has resulted in Apohem transferring data to Meta about customers who have initiated or completed purchases on the company's website. The initiated purchases have included situations where customers have manually filled in their personal information in the checkout form and proceeded in the purchasing process but did not complete the purchase. The transferred data has consisted of, for example, names of goods and non-prescription products as well as customer contact information in the form of first and last name, postal address, email address, and phone number. Information about prescription medications has not been transferred. Apohem has also had the pixel code installed on parts of the website that have included, among other things, contraceptives, emergency contraceptive pills, sex toys, self-tests, and treatment of sexually transmitted diseases, products for vaginal health, prostate, rectal, and urinary issues, stoma products, as well as products for monitoring and treating diabetes.

It has further emerged that Meta has implemented a so-called filtering mechanism aimed at attempting to detect and delete information that has been transferred to Meta in violation of Meta's policy.

According to a statement from Meta dated February 16, 2024, the mechanism is designed to detect and delete potentially prohibited information, such as data concerning health and finance, in data that users of the pixel transfer to Meta before it is stored and used in Meta's advertising system. When such data is detected and deleted, the user receives a notification about it, but the filtering mechanism also functions even if such a message is not sent to the user.

Apohem has contended that Meta's statement seems to be based on current conditions regarding how the filtering mechanism operates. However, IMY notes that there is nothing in the investigation that indicates that the filtering mechanism has functioned differently during the relevant time period in this case.

IMY thus concludes that the investigation in the matter shows that the pixel did not contain a filtering mechanism that prevents the transfer of data to Meta. The filtering mechanism is designed to filter out potentially privacy-sensitive data only after it has been transferred to Meta and if their system has been able to identify that the transferred data contains such prohibited information. The absence of notifications about prohibited and deleted information cannot, in itself, be considered confirmation that potentially privacy-sensitive data has not been transferred to Meta.

In summary, the existence of the filtering function has not prevented the established transfer of

personal data to Meta.

IMY makes the following assessment of the risks associated with the current personal data processing. Processing that involves so-called sensitive personal data normally entails higher risks. The concept of sensitive personal data should be interpreted broadly and also includes data that indirectly reveals such information. Apohem has transferred data to Meta regarding which product the customer has initiated or completed a purchase of, as well as data that identifies the customer in the form of first and last name, postal address, email address, and phone number. IMY notes that the combination of data that has been transferred has made it possible to ascertain that a specific person has purchased a certain identified product.

Integrity Protection Authority

Diary Number: IMY-2022-3272

10(15)

Date: 2024-08-29

Apohem has not transferred any data regarding prescription products. However, IMY believes that the majority of products in the company's other assortment, and for which the company has transferred data, are of such a nature that information about a person purchasing such a product could reveal information about the individual's health condition or sexual life. This includes, for example, stoma products, products for vaginal health, prostate, rectal, and urinary issues, products for monitoring and treating diabetes, self-tests and treatment for sexually transmitted diseases, contraceptives, emergency contraceptive pills, as well as sex toys. Apohem has argued that the buyer is not necessarily the actual user of the product and that the processing therefore has not involved sensitive personal data. However, IMY believes that it is likely that at least some of the purchases of, for example, stoma products, products for rectal, urinary, and prostate issues, vaginal issues, as well as treatment for diabetes and sexually transmitted diseases have been made for personal use in order to treat a specific health condition. IMY thus assesses that the processing likely involved data about health in the sense intended in Article 4.15 of the General Data Protection Regulation. The same assessment is made regarding purchases of, for example, emergency contraceptive pills and sex toys, meaning that it is likely that the purchases in some cases have been made for personal use and that the processing has thereby revealed information about the individual's sexual life. In assessing the appropriate level of protection, Apohem should therefore have considered that the processing could involve sensitive personal data.

IMY assesses that the data regarding purchases of products, regardless of whether the data constitutes sensitive personal data or not, is of such a privacy-sensitive nature that it requires a strong level of protection according to the General Data Protection Regulation. Furthermore, the processing has been carried out by a pharmacy where the customer can be assumed to have special expectations that their personal data is handled with a high degree of confidentiality. Against this background, IMY notes that both the nature of the personal data and the context in which it has been processed have resulted in increased risks to the rights and freedoms of the data subjects.

Apohem estimates that approximately 15,000 data subjects have been affected by the personal data incident. The estimate is based, among other things, on the number of website visitors who have had an account on Facebook or Instagram and could be matched through the AAM function. Apohem has further listed categories of products that have been available for purchase on the parts of the website where the pixel code has been installed and stated that the total share of the company's sales that pertained to these products amounted to 5.7 percent during the relevant period. IMY assesses that based on this information, even though it is not possible to determine exactly how many initiated or completed purchases have been made for personal use or the exact amount of personal data that has been transferred to Meta through the AAM function, it can at least be established that it involves extensive processing of personal data.

In summary, IMY assesses that the nature, scope, and context of the processing have posed high risks that have resulted in a requirement for a high level of protection for the personal data. The measures should, among other things, ensure that the personal data is protected against unauthorized disclosure and loss of control.

Apohem has not implemented sufficient security measures.

IMY will then assess whether Apohem has ensured the high level of protection required for the personal data.

Apohem has stated that the company has internal routines and governing documents to ensure proper handling of personal data before, in connection with, and after the introduction of...

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3272

11(15)

Date: 2024-08-29

new features on the website. In the implementation of the Meta pixel on the website, the company conducted a risk analysis of the pixel and assessed that the processing of personal data would not pose a high risk to the rights and freedoms of the data subjects. The company also made a selection and categorization of which products would be marketed in Meta's channels. However, Apohem had the pixel code installed on pages with privacy-sensitive products that would not be included in the marketing. Apohem did not take technical security measures to prevent data about customers' initiated and completed purchases of these products from being transferred to Meta.

Apohem further stated that regular follow-ups on the information collected and processed through the Meta pixel had not been conducted. Instead, the company relied on Meta's filtering mechanism to detect and delete information of a privacy-sensitive nature processed through the pixel. This led to the unauthorized transfer of personal data continuing for over a year, and the company became aware of and stopped the transfer only when an external source pointed out what was happening.

Since Apohem only had procedures for following up documented changes made according to established routines, Apohem lacked the ability to detect and address other changes that had actually been made or occurred in other ways. Against this background, IMY finds that the company has lacked organizational routines to systematically follow up on unintentional changes in its systems.

IMY thus assesses that Apohem has not taken appropriate technical and organizational measures in relation to the high risk that the processing has entailed. The company has therefore processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

Choice of Intervention

Applicable Provisions, etc.

If there has been a violation of the General Data Protection Regulation, IMY has a number of corrective powers available under Article 58.2 of the General Data Protection Regulation.

According to Article 58.2 of the General Data Protection Regulation, IMY shall impose administrative fines in accordance with Article 83, in addition to or instead of other corrective measures referred to in Article 58.2, depending on the circumstances of each individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the General Data Protection Regulation.

Article 83.2 specifies the factors to be considered in determining whether an administrative fine should be imposed, as well as what should influence the amount of the fine. Relevant to the assessment of the seriousness of the violation are, among other things, its nature, severity, and duration.

According to Article 83.4, in cases of violations of, among other things, Article 32, administrative fines of up to 10,000,000 EUR or, if it concerns a company, up to 2 percent of the total global annual turnover in the preceding financial year shall be imposed, depending on which value is higher.

Integrity Protection Authority

Diary Number: IMY-2022-3272

12(15)

Date: 2024-08-29

The EDPB has adopted guidelines on the calculation of administrative fines under the Data Protection Regulation aimed at creating a harmonized method and principles for calculating fines.⁹

If it concerns a minor violation, IMY may, as stated in Recital 148 of the Data Protection Regulation,

instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b.

IMY's Assessment

A fine shall be imposed

IMY has assessed that Apohem has processed personal data in violation of Article 32.1 of the Data Protection Regulation.

The violation occurred because Apohem processed personal data with an insufficient level of security, which resulted in sensitive personal data about a large number of data subjects being inadvertently transferred to Meta during the period from April 15, 2021, to April 26, 2022. Unauthorized access to such data poses a high risk to the freedoms and rights of the data subjects. IMY believes that this is not a minor violation that could warrant a reprimand instead of a fine.

The Court of Justice of the European Union has clarified that it is required that the data controller has committed a violation intentionally or negligently for administrative fines to be imposed under the Data Protection Regulation. The Court has stated that data controllers can be imposed fines for actions if they cannot be considered to have been unaware that the action constituted a violation, regardless of whether they were aware that they were disregarding the provisions of the Data Protection Regulation.¹⁰

According to the principle of accountability, which is expressed, among other things, in Article 5.2 of the Data Protection Regulation, those responsible for the processing of personal data must ensure and be able to demonstrate that the processing is in compliance with the Data Protection Regulation.

IMY notes that Apohem is therefore responsible for ensuring that the personal data processed in its operations is processed in a manner that ensures an appropriate level of security. IMY has determined in its assessment that the company has not met the requirements set by the Data Protection Regulation in this regard. Apohem cannot be considered to have been unaware that its actions constituted a violation of the Regulation.¹¹

IMY thus assesses that the conditions for imposing an administrative fine on Apohem for the violation are met. In determining the amount of the fine, IMY shall consider the circumstances specified in Article 83.2 and ensure that the administrative fine is effective, proportionate, and dissuasive.

Starting Points for Calculating the Fine

The annual report for the financial year 2023 shows that Apohem had an annual turnover of 603,000,000 kronor. Since IMY has established a violation of

9 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under GDPR adopted on May 24, 2023.

10 Judgment of the Court of Justice of the European Union in Case C-683/21 Nacionalinis visuomenės sveikatos centras prie Sveikatos apsaugos ministerijos v. Valstybinė duomenų apsaugos inspekcija of December 5, 2023, paragraph 81, and judgment in Case C-807/21 Deutsche Wohnen of December 5, 2023, paragraph 76.

11 See also the assessment of negligence in the Administrative Court of Stockholm's judgment on March 11, 2024, in case 2829-23, p.12.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3272

Page 13 of 15

Date: 2024-08-29

According to Article 32 of the General Data Protection Regulation, the maximum sanction amount that can be determined in the case according to Article 83.4 shall be 10,000,000 EUR or two percent of the total global annual turnover during the previous financial year, whichever value is higher. Two percent of the company's annual turnover for 2023 is 12,060,000 SEK. Therefore, the highest sanction fee that can be established in the case is 10,000,000 EUR.

Severity of the Violation

According to the EDPB's guidelines, the supervisory authority must assess whether the violation is of low, medium, or high severity.¹²

In assessing the severity of the violation, IMY takes into account the following circumstances. The

relevant security breaches have led to an incident that has affected a large number of data subjects, and that Meta has been able to access a significant amount of personal data that should not have been transferred to them for an extended period. The data has included sensitive personal data about directly identifiable customers, meaning data that requires a high level of protection. Furthermore, the violation occurred in a pharmacy operation where the data subjects must be considered to have had a legitimate expectation of high confidentiality and that their personal data would not be disclosed to unauthorized parties. The sale of over-the-counter and other health-related products must also be considered part of Apohem's core business, which makes the violation more serious than if that were not the case.¹³

Moreover, IMY considers that Apohem had implemented a number of appropriate technical and organizational security measures at the time of the violation. The personal data has also been transferred in hashed, that is, unreadable, format to a single recipient, and thus it does not involve uncontrolled disclosure where the data has, for example, been shared with many unauthorized parties or been publicly available on the web.

In a comprehensive assessment based on the above circumstances, IMY considers that this constitutes a violation of Article 32.1 of the General Data Protection Regulation of low severity.

In its assessment of the size of the sanction fee, IMY shall also take into account such aggravating and mitigating factors as listed in Article 83.2 of the General Data Protection Regulation. After the violation, Apohem has, among other things, attempted to contact Meta regarding the transfer of personal data and has developed new governing documents and procedures to reduce the risk of similar incidents. Apohem also completely disabled the pixel when the company became aware of the transfer.

However, IMY notes that these measures were taken only after the company was alerted to the relevant deficiencies by an external source. The measures taken cannot, according to IMY, be considered to go beyond what is expected of Apohem in the current case. They are therefore not of such a nature that they affect IMY's assessment of the size of the sanction fee in a mitigating direction. The same applies to the fact that Apohem submitted a report of the personal data incident to IMY, as this constitutes a circumstance that should be considered neutral in determining the sanction fee.¹⁴ IMY notes that no other circumstances have emerged that affect the assessment of the size of the sanction fee, either in an aggravating or mitigating direction.

¹² EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 60.

¹³ The more central a processing activity is to the data controller's operations, the more serious the inaccuracies in the processing become. See EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 53.

¹⁴ EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 98.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3272

Page 14 of 15

Date: 2024-08-29

The Sanction Fee Must Be Effective, Proportionate, and Deterrent

The administrative sanction fee must be effective, proportionate, and deterrent. This means that the amount must be determined so that the administrative sanction fee leads to rectification, provides a preventive effect, and is also proportionate in relation to both the current violations and the supervisory subject's ability to pay.

In light of the severity of the violation, IMY determines that Apohem shall pay an administrative sanction fee of 8,000,000 SEK for the established violation. IMY assesses that this amount is effective, proportionate, and deterrent.

This decision has been made by the acting Director General David Törngren after presentation by the lawyer Shirin Daneshgari Nejad. In the final processing, the acting Legal Director Cecilia Agnehall, Unit Manager Nidia Nordenström, Lawyer Maja Welander, and IT and Information Security Specialist Petter

Flink have also participated.

David Törngren, 2024-08-29 (This is an electronic signature)

Appendix

Information on Payment of Sanction Fee

Copy to

DSO

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3272

Page 15 of 15

Date: 2024-08-29

How to Appeal

If you wish to appeal the decision, you must write to IMY. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you received the decision. However, if you are a party representing the public interest, the appeal must be received within three weeks from the day the decision was announced. If the appeal has been submitted in time, IMY will forward it to the Administrative Court in Stockholm for consideration.

You may email the appeal to IMY if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.